

Law & CS Project: Group 1 NLP Legal Memo

To: Rebecca Williams and Tom Melham

From: Group 1 NLP (SIFTIT)

Table of Contents

<i>Introduction</i>	<i>2</i>
<i>Project Overview.....</i>	<i>2</i>
<i>MPC and Data Protection Laws.....</i>	<i>3</i>
GDPR and MPC	3
MPC and the GDPR Framework.....	4
Status of PETs under the GDPR	5
MPC as anonymization - Proof of Concept:	8
Risks with MPC and data processing.....	14
<i>UK DPA.....</i>	<i>15</i>
Cross-Border Transfers	15
Age of Data Processing Consent	15
Anonymisation/Pseudonymisation.....	15
Fines.....	16
<i>Other International Jurisdictions.....</i>	<i>17</i>
South Africa	17
The United States of America	17
<i>IP and Licensing</i>	<i>18</i>
<i>Legal Ethics.....</i>	<i>19</i>
Executive Summary.....	19
Introduction.....	19
Identifying Potential Sources of Biases.....	20
Bias Types and Potential Impacts	20

Mitigating Biases	21
<i>Conclusion</i>	22

Introduction

The purpose of this memo is to set out and analyze the key legal issues which arise in relation to our group project. First, we will provide a brief overview of our project, the technologies used and the proposed commercial implementation of the product. Then, we examine the three primary legal issues identified. The first is the legal status of Secure Multiparty Computation (MPC) under various data protection laws. The ultimate finding on this point is that whether MPC achieves anonymization to the extent necessary to take the processed data outside the scope of data protection laws will depend on the exact technical features of the MPC process employed. Second, we consider IP and licensing questions arising in relation to the commercialization of our product. The ultimate finding here is that as the Product is a plug-in that enhances the functionality of an existing email software program, without altering the programme's source code or existing functionality. As a result, the Product is not expected to infringe on any intellectual property rights, such as patents or copyrights, that are held by the email software program's owner. However, in some cases, it may be necessary to comply with the email software programme's terms of use and other applicable policies. These policies may require technical compatibility with the email software program, which must be followed to ensure that the Product and the underlying software function complementarily. Finally, we consider the ethical implications of the technology employed in this context. Here, we conclude that there is a significant risk of a dataset sample bias, which we address through three mitigation strategies.

Project Overview

Our group project is an email classifier product called 'SIFTIT'. The two primary technologies employed in this product are natural language processing (NLP) and secure multi-party computation (MPC). NLP is used to classify emails according to given labels and augmented with MPC to do this in a privacy-preserving way. MPC is also used to provide a 'data secure' means of training and updating the model based on data collected from real-life use in industry.

The NLP model used was a pretrained DeBERTa model from the Hugging Face library. We perform online transfer learning on this model, by training only its final layer for the task of classifying emails. MPC was integrated with the NLP model with the CrypTen library, making this

final layer an MPC one – this maintains the privacy-preserving property key to our product, while minimising the extra computational cost imposed by MPC.

The proposed method implementation of this product for the purpose’s commercialization is as an extension in Outlook, Thunderbird or other corporate email providers. Potentially, one may discuss adding an on-premises server (onsite of the law firm), or within a trusted cloud environment if they are already operating in one, which would help speed up the computers of the lawyers.

MPC and Data Protection Laws

The use of MPC to provide for ongoing training and updating of the model after it is deployed raises several interesting legal questions. Furthermore, the legality of our and the firm’s processing of emails containing personal data more generally requires consideration.

GDPR and MPC

When considering the interaction of any privacy enhancing technology (‘PET’) with the General Data Protection Regulation (GDPR), the key question is whether the technology achieves i) the pseudonymization or ii) the anonymization of the personal data being processed (‘the data’). If anonymization is achieved, the data will fall outside the scope of the GDPR. This greatly lessens the administrative burden of GDPR compliance processing parties. If the technology merely achieves pseudonymization, the data will remain personal data for the purposes of the GDPR. In the latter case, the technology nonetheless serves to fulfil the requirements of ‘Privacy by design’, thereby helping to ensure that data processing remains lawful.

Multiparty Computation (MPC) is a PET which can allow multiple parties to perform data analytics without the need to share the underlying data. Having regard to the GDPR, guidance from the European Commission, the UK ICO, and recent academic literature on the subject, this report considers whether MPC achieves pseudonymization or anonymization under the GDPR, and what legal risks may be associated with the use of this technology in data processing. The prevalent view is that MPC, along with other PETs, resembles pseudonymization. It is submitted that however, that a closer examination of the technical process of MPC reveals that true anonymization is, in fact, achievable if certain technical safeguards are implemented into the MPC mode.

MPC and the GDPR Framework

To clarify the legal framework, the meaning of several key terms in the GDPR must be examined:

i) Personal Data

Standard personal data (Article 4(1) GDPR) -

Personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.

The processing of this data must comply with the principles in the GDPR.

Special personal data (Article 9(1) GDPR) -

Special personal data is personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation.

The processing of such data is prohibited save for in special circumstances set out in Article 9(2) GDPR.

ii) Lawful processing (Article 6(1) GDPR)

Article 6(1) GDPR sets out six conditions under which the processing of personal data is lawful. This includes, for example, where the data subject has given their consent to the processing for one or more specific purposes or where the processing is necessary for compliance with a legal obligation.

Article 6(4)(e) provides that where the processing is not based on the consent of the data subject or a Union or Member State law requiring the processing for a proportionate measure having regard to the public interest in a democratic society, particular consideration should be given to the use of encryption or pseudonymisation.

iii) Privacy by Design (Article 25 GDPR)

Privacy by Design provides that the data controller must, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to

implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects.

This should be done taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing.

iv) Pseudonymization (Article 4.5 GDPR)

Pseudonymisation' means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.

v) Anonymization (Recital 26 GDPR)

According to Recital 26 GDPR, anonymized information is “information which does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable”. Accordingly, the principles of the GDPR should not apply to anonymous data.

vi) PET

PETs are technologies that can help organisations share and use people's data responsibly, lawfully, and securely, including by minimising the amount of data used and by encrypting or anonymising personal information.[1]

The principles of Privacy by design (embedded in Article 25 GDPR) require the use of PETs to make data breaches more difficult.

Status of PETs under the GDPR

i) GDPR text

The GDPR refers to PETs only in the context of privacy by design in Article 25. Pseudonymization and encryption are mentioned specifically.

ii) Working Party Opinion 05/214

Working Party Opinion 05/214 discussed the possible application of PETs to achieve anonymization under the GDPR and stated the following:

“An effective anonymisation solution prevents all parties from singling out an individual in a dataset, from linking two records within a dataset (or between two separate datasets) and from inferring any information in such dataset. Therefore, removing directly identifying elements is not enough to ensure that identification of the data subject is no longer possible. It will often be necessary to take additional measures to prevent identification, once again depending on the context and purposes of the processing for which the anonymised data are intended”

It also provided three questions that must be answered in the negative to pass the robust anonymisation test:

- (i) is it still possible to single out an individual
- (ii) Is it still possible to link records relating to an individual, and
- (iii) can information be inferred concerning an individual?

The fact that processing before anonymization will always include processing before anonymization was emphasised. During the pre-anonymization phase, the data remains within the scope of the GDPR.

The possibility of organisational measures which, despite ostensibly successful anonymization on the technical level, may lead to a data breach was also discussed.

iii) ICO guidance¹

In this guidance, PETs are noted for their value primarily in assisting compliance with data protection law. Notably, it can help parties to demonstrate compliance with the data minimisation principle, as no one should learn anything from the data beyond what is absolutely necessary to perform the legitimate function. It is also noted that PETs can help to minimise the risk of personal data breaches when performing processing with other parties since data is not stored together.

While not dealing with the question explicitly, the guidance does consider the technical requirements necessary to prevent ‘reidentification’ or ‘reconstruction’ of data by one or more parties, or by a hacker post-MPC. It briefly mentions that ‘it is important to determine what the appropriate ‘threshold’ is for the number of secret shares your use of SMPC involves’ when

¹ ICO – Sept 2022 - Chapter 5: Privacy-enhancing technologies (PETs) Draft anonymisation, pseudonymisation and privacy enhancing technologies guidance

determining whether reconstruction is possible. It is submitted that this tacitly accepts that, if correctly designed, MPC may reach the non-identification standards required for anonymization.

iv) Eurostat (European Commission) Document²

An interesting Eurostat presentation that was found during our research addressed the question of whether the “dilution” of source data through MPC (the secret sharing or encryption of the data with a diluted key) would take personal data outside the scope of the GDPR (anonymization).

Though it didn’t say that this was technically impossible, it indicated that “endorsement of this view by DPA’s is unlikely” in their view. Rather, DPA’s would be more likely to endorse the conservative approach of SPC ‘strengthening’ GDPR implementation (pseudonymization).

Conclusion -

The guidance reviewed was generally conservative on the question of whether MPC, it is clear. Ultimately, it seems, the assessment of whether a particular MPC process was sufficient to result in anonymization of personal data will be assessed on a case-by-case basis.

Regardless of whether pseudo anonymization is achieved by the technology, it is clear that MPC is favourably regarded by DPAs as a powerful tool in ensuring compliance with the best-practice principles of the regulation. Such compliance is important not only to prevent data breaches, but to limit the liability of undertakings in the case that such a breach occurs.

² Ricciato, F. (2021). *Access to external data for the production of official statistics and personal data protection: what can we demand from Secure Private Computing technologies?*
https://ec.europa.eu/eurostat/cros/system/files/istat_23june2021_ricciato_slides_0.pdf -
accessed March 6th 2023.

MPC as anonymization - Proof of Concept:



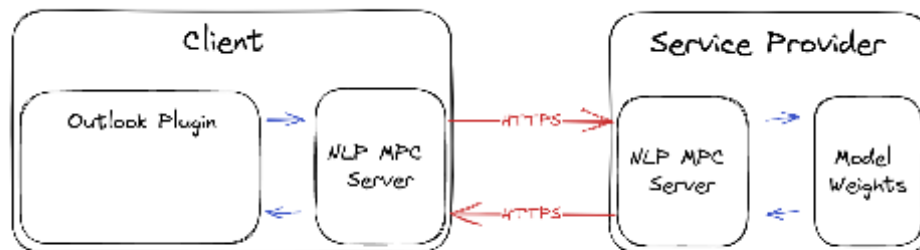
Case Study

Assumptions

Since we (the server operator) enter contractual agreements with our clients, we assume a semi-honest threat model. This means that none of the involved parties would corrupt the computations, and all provide information honestly. Nonetheless, it is assumed that the clients may be curious and exchange information to potentially learn secret data.

The MPC protocol is chosen in a way to address this specific threat model. More secure protocols could be used, at the cost of performance.

Technical Setup



All communications are encrypted (not included in the PoC) to prevent tampering by third parties. Note that the red lines in particular indicate that even if it were readable by an attacker, it would not reveal any information. Here it's supposed to illustrate information flows that are meaningless (do not reveal information on the original data), apart from their purpose to potentially update model weights.

The NLP MPC Server accepts requests from the Outlook Plugin, encrypts the data and engages with the NLP MPC Server from the service provider to evaluate their model on

the clients' data. The clients' MPC server decrypts the predicted label and forwards that back to the outlook plugin.

The service provider and the client additionally use a trusted third party which provides so-called *Beaver triplets* that are required for the multiplications in the NLP model.

MPC Process

Step 1: Client prepares the data [Client-Side]

Each email is associated with a unique identifier (e.g., either simply the ID of the email in the database, or a cryptographic hash from the sender/receiver address and the time and date). This is required to correctly associate label predictions with the email. Only the client knows the ID - Email relation, and the identifier as such reveals no private information.

Email Identifier	Email
f25d9c52	Good afternoon, ...
d37e9512	Hello Angela, could you...

Step 2: NLP Preprocessing [Client-Side]

The email message is run through a preprocessing NLP pipeline, which tokenizes the input and then computes a high-dimensional embedding (context-rich representation) of the email.

Email Identifier	Email	Embedding
f25d9c52	Good afternoon, ...	[0.1174, 0.9917, 0.4426, ...]
d37e9512	Hello Angela, could you...	[-1.2324, 0.2673, 0.6215, ...]

Note that this embedding may still contain PII. At this point, no data has left the client, or shared with anyone else.

Step 3: Secret-Sharing Model Weights and Embedding

The embedding is split into two shares. By properties of secret shares, they are individually indistinguishable from random, and therefore, on their own, do not contain

PII.

Formally, if x is the embedding, then $[x] = (x_1, x_2)$, s.t. $x = x_1 + x_2 \bmod 2^k$ are the secret shares of x (where k is a security parameter of the protocol). Let $r \in [0, 2^k - 1]$ be chosen uniformly at random. We set $x_1 = x - r \bmod 2^k$ and $x_2 = r \bmod 2^k$. It is then obvious that both x_1 and x_2 are indistinguishable from random, if r is unknown to anyone who didn't create the secret shares.

The client keeps one of the shares, and gives the service provider the other one.

The same steps are performed by the model provider with regards to the model weights.

At this stage, both the client and the service provider have pieces of information from each other, from which they could not possibly reconstruct the original data (just as hard as guessing the PII randomly).

Step 4: Computing the label

The secret shares of the data (indistinguishable from random) are then passed through a single-layer perceptron, that is, they compute

$$[Y] = ReLU([W][X] + [b])$$

where $W \in \mathbb{R}^{3 \times 768}$, $X \in \mathbb{R}^{768 \times b}$, $b \in \mathbb{R}^3$, $Y \in \mathbb{R}^{3 \times b}$. Note that secret matrix-vector multiplication can be performed as follows:

$$([W][X])_{i,j} = \sum_{k=1}^{768} [W]_{i,k} [X]_{k,j}$$

At this point, we note that the multiplication of two secret shares involves a trusted 3rd party. This party does **not** receive any (encrypted) data, but rather assists in the computation by creating so called "Beaver Triples" which can be pre-computed before the data is known. This 3rd party must, however, be trusted (i.e., does not secretly collaborate with the client or the server) - otherwise information leakage is possible.

So far, neither the client nor the server has learned any information about the data or the model weights. Every piece of data is indistinguishable from random.

Step 5: Revealing the label

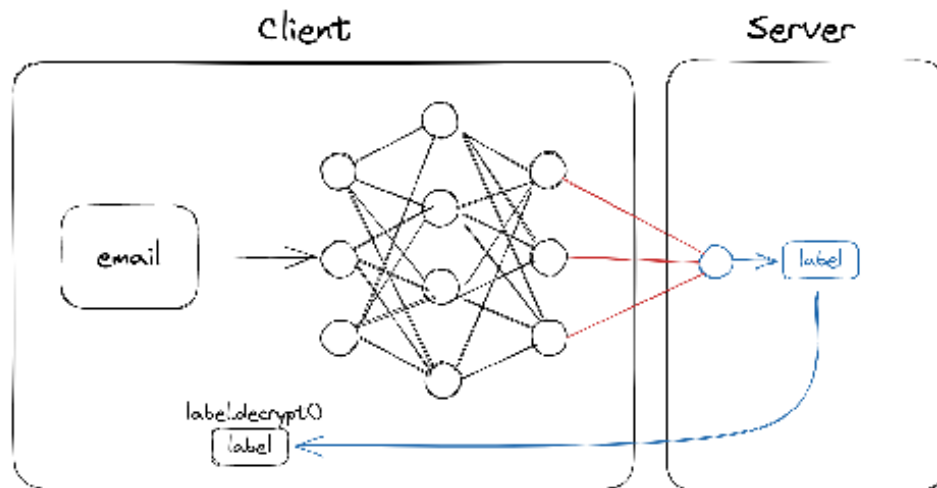
The server and the client share the secret $[Y] = (Y_1, Y_2)$, that is, the server knows Y_1 , the client knows Y_2 , but neither know the actual label Y .

The server now sends Y_1 to the client, which can then compute $Y = Y_1 + Y_2$ (only the client learns Y).

Note that the function *ReLU* is not invertible, so the client cannot uniquely determine W, b from Y (i.e., the model remains secret).

Step 6: Training the model

This is where things get more challenging. Currently, the setup consists of the local, client-side part of the model, and the MPC final layer classification module that is computed by both the client and the server.



Red lines are known only to the server, and blue lines are results computed by the server, but only decryptable by the client. In this case, the server learns no information at all.

But when the client corrects a label that it receives (and sends a secret share of the label to the server), the server and client use MPC to update the weights without revealing the original input (final layer of the DeBerta model), or the weights to the client.

However, the updated weights are known to the server, so it knows the gradient. Knowing the gradient, the paper "[Deep Leakage from Gradients](#)" shows that we would be able to reconstruct the final-layer representation and label from the client, by trying to replicate the gradient using optimization methods.

Now, the final layer of the DeBERTa model itself reveals a lot of information about the original text, with high chance also personally identifiable information, since DeBERTa was trained using an encoder-decoder model.

The paper also proposes some methods to limit this attack, in particular gradient pruning (setting all gradient entries to zero that are below a certain threshold), which could be implemented relatively easily using MPC (at the cost of accuracy).



What can be recovered

Original email and corrected classification label **if** the user corrects the original classification.

Note: This is only possible if we (the third party) were to keep a copy of the old weights or store the gradients (which we don't). Otherwise, **PII is not recoverable**.



What cannot be recovered

Original email and label **if** the user **does not** correct the original classification

An attacker on our server would only get our weights, which themselves do not allow PII recovery.

Other ways of information leakage: Model Weights with Informed Adversaries

"[Reconstructing Training Data with Informed Adversaries](#)" is an interesting paper, albeit unrealistic. It shows that if the adversary knows the model weights and all of the training data except for a single data point, they can reconstruct that data point. In our example, that would correspond to the following setting:

Our server is attacked and the model weights copied by the attacker. The original training data of the model is public, so for the very first email where a company corrects the classification, the attacker would be able to infer the email just from the weights. As soon as more than 1 update has been performed on the model weights, this attack becomes significantly harder, as the number of unknowns increases. A formal mathematical proof is out of scope of this case study.

In a more general setting (after several model updates), it is unfeasible to reconstruct training data from the model weights. In that case, we pass the anonymity test:

- (i) is it still possible to single out an individual, ($\rightarrow$ no)
- (ii) Is it still possible to link records relating to an individual, and ($\rightarrow$ no)
- (iii) can information be inferred concerning an individual? ($\rightarrow$ no)

Conclusion

The above steps illustrate that anonymity can be guaranteed for basic inference, as well as for training if the necessary safeguards are put in place. These anonymity safeguards for training are technically feasible (as explained above), but have not yet been implemented in our proof of concept.

In our demo, for training, we do, however, fulfill pseudonymisation since "the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person;" ([Article 4\(3b\)](#)). In our case, the additional information are the gradients obtained in the training process.

Risks with MPC and data processing

The literature reviewed highlighted several risks associated with the use of MPC in processing personal data.

Process risks

The ICO guidance emphasised the risk in handling personal data before it is processed using MPC. The guidance correctly notes that in preparation for MPC analysis, the data will need to be collated and processed. During this pre-processing processing stage, the data is unquestionably personal data and must be processed in accordance with the GDPR.

Party risks

Non-compliance with MPC protocol -

Depending on the threat model implemented, MPC will depend to a certain extent on the honesty of the parties. Dishonest parties working together may be able to reconstruct the input data under certain conditions. Ideally, the threat model selected would require a low proportion of parties to be honest. This can be achieved with robust access controls, logging and auditing mechanisms and a strong contractual framework (ICO guidance).

Competition law concerns -

Toldsepp, Pruulmann-Vengerfeldt and Laud have voiced concerns that MPC may be used to facilitate market collusion between competing parties, a practice which is outlawed by cartel and competition laws.³ Such collusion can again be preventing by implementing a robust threat model as described above.

³ Toldsepp, K., Pruulmann-Vengerfeldt, P., & Laud, P. (n.d.). Usable and Efficient Secure Multiparty Computation. *Future and Emerging Technologies (FET-Open) Deliverable D1.2 Requirements Specification Based on the Interviews*. Retrieved March 6, 2023, from <http://www.usable-security.eu>.

UK DPA

The GDPR was essentially transposed into UK law through what is often referred to as the 'UK GDPR'.⁴ The Data Protection Act 2018 ('DPA') is the UK's primary data protection legislation, and it supplements the provisions of the UK GDPR by setting out additional requirements and exemptions specific to the UK. The DPA also includes provisions related to the processing of personal data for law enforcement purposes, which are not covered by the GDPR. Some subtle differences exist between the two regimes, which we have identified as follows.

Cross-Border Transfers

One of the main differences between the UK GDPR and the EU GDPR is the way in which they relate to the European Economic Area (EEA). Under the EU GDPR, data transfers between the EU and the EEA are considered "intra-EU" transfers and are not subject to additional safeguards. However, now that the UK has left the EU, data transfers between the UK and the EEA are considered "cross-border" transfers and are subject to additional safeguards.

Age of Data Processing Consent

Another key difference is that the UK GDPR allows for more flexibility in certain areas, such as the age at which children can give their own consent to data processing - age 13 in the UK, compared to age 16 under the EU GDPR.⁵

Anonymisation/Pseudonymisation

Under the DPA, data controllers *and* processors have obligations to implement appropriate technical and organisational measures to ensure a level of security appropriate to the risks arising from the processing of personal data.⁶ Controllers, additionally, when proposing a particular *type* of processing "consider the impact of the proposed processing on the rights and

⁴ Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (United Kingdom General Data Protection Regulation)

⁵ DPA 2018 s9(a)

⁶ DPA 2018, s66(1)

freedoms of data subjects”.⁷ The DPA 2018 requires that controllers take into account all available means to *minimise* the risk of re-identification and implement *appropriate* technical and organisational measures to ensure that re-identification is not likely to occur. A fool-proof system is not the expectation, but demonstrable and reasonable efforts are required to discharge this statutory duty.

Both the UK and EU GDPR recognise the concepts of anonymization and pseudonymisation.⁸ The above statutory requirements under the DPA set a general baseline for compliance which would be supported through adherence to ICO guidance and the UK GDPR’s provisions.⁹

Fines

There is a slight post-Brexit difference in fines. The 4% annual turnover requirement remains as an alternative, but the fixed maximum is £17,500 under the DPA compared with €20,000.¹⁰ The effect of this is to render the maximum fixed on the exchange rate set by the Bank of England, and not the European Central Bank.

⁷ DPA 2018, s103(1)

⁸ See recital 28 of either GDPR version

⁹ See e.g. Information Commissioner’s Office, “Draft anonymisation, pseudonymisation and privacy enhancing technologies guidance” February 2022

¹⁰ DPA 2018, Schedule 21, Part 6, Paragraph 16(a)

Other International Jurisdictions

In addition to complying with the GDPR and DPA, we are expanding our focus to other jurisdictions, both developed and emerging economies, recognising that many of our users may have offices or business interests outside of Europe. As such, we are considering the United States, a well-established economy, and South Africa, an emerging economy, to ensure comprehensive compliance with privacy regulations.

South Africa

Unlike the GDPR, the South African's Protection of Personal Information Act (POPIA) does not define anonymisation; rather, it provides guidelines for the de-identification of personal information. Once, the data is de-identified – and cannot be reversed, there is compliance under the POPIA.

That said, de-identification of personal information, which involves removing or obscuring identifiers that could identify an individual, may be considered as data processing under POPIA if the 'data processor' carries out the de-identification itself. In other words, where the data, at the point of collection were already de-identified, there is no data processing.

The United States of America

CCPA (California Consumer Privacy Act) – an equivalent of GDPR, "de-identified information" as: "Data, which cannot reasonably identify, relate to, describe, be capable of being associated with, or be linked, directly or indirectly, to a particular consumer." This definition clarifies the level of anonymisation required for data to be considered de-identified under the CCPA and can help the MPC that the Product leverages on, to ensure compliance with CCPA regulations when classifying and prioritising emails.

In sum, as the Product only collects de-identified or anonymised data, there is no risk of data being processed under the POPIA or the CCPA. In any event, we believe the underlying privacy notice of the users of the Product would cover the processing of the personal data arising of emails that are classified.

IP and Licensing

Being a plug-in that enhances the functionality of an existing email software programme, we considered the potential intellectual property concerns - especially patents and copyrights that may arise.

Although we note that more jurisdictions vest exclusive derivative and related rights on copyrighted works, and in case of patent, the right to use, the creation of a plug-in without altering the programme's source code or existing functionality does not engage any existing copyright or patent right. Bolstering this conclusion, we note the distinction between a plug-in and an add-in. While the latter attaches itself to the source code and functions primarily from the source code, the former may exist as an extension, and is independent of the source code of the underlying software programme. Based on this distinction and the design of the Product as set out in the earlier part of this Memo, we believe that the Product is not expected to infringe on any intellectual property rights that are held by the email software programme's owner.

That said, we note that while licence or permission is not required from the copyright owner or patent holder in respect of the underlying email software before proceeding with the deployment of the Product, the term of use of some emails may require that technical compatibility with the email software programme to be followed to ensure that the Product and the underlying email software function complementarily. In this wise, we reviewed the term of use of notable email software including Gmail, Outlook, Apple Mail and Thunderbird. A common theme for all the email software is that the Product is required to be registered through each email software developer's programme, and through the registration, the Product will be required to comply with the relevant developer policies and guidelines as they may apply to plug-ins.

Legal Ethics

Executive Summary

This section provides an ethical assessment of Siftit's NLP-based e-mail sorting model (the "Model"), from the point of view of possible algorithmic biases that may produce unfair outcomes.

In conclusion, we identify a critical possible allocative harm in training and operating the Model:

The NLP model may be fraught by a dataset sample bias (i.e. the sample emails used to train the model are not representative of language used by all groups in society).

- Such a distorted dataset sample may lead to unfair prioritisation (i.e. favouring those represented in the dataset) and categorisation of emails from different groups whose language use the Model is not trained on.
- During product development, onboarding and after-sales, we will mitigate this issue by:
 1. Ensuring **wide demographic coverage in collecting sample emails** that make up our training dataset for each client.
 2. Including a **demographic assessment** stage when onboarding each client, where we identify as many segments of the demographic the client interacts with as possible and define reasonable thresholds for each segment in the dataset.
 3. Implementing **regular monitoring, testing and evaluation of** the Model's performance for each client.

Introduction

Siftit's NLP-based email classification and prioritization tool (the "Model") is designed to help users efficiently manage their email inbox by automatically categorising and prioritising emails.

Given the potential for algorithmic biases to influence the Model's outcomes (e.g. whose emails get prioritised for the client and how they are categorised and thus processed), an ethical assessment is necessary to evaluate the Model's fairness, transparency, and potential impact on users and society.

Identifying Potential Sources of Biases

This assessment will focus on evaluating the specific components and processes of the Model (together, the “Components”) that could lead to algorithmic biases, including:

- the pretrained model which we used to build the Model,
- the training data, and
- the context of deployment of the model.

Above all, the training dataset of email messages is susceptible since it may contain biases related to a given sender's demographic characteristics, language, or cultural context. We will therefore focus our analysis on this component.

We note, however, that the algorithms and other resources used to build the Model may also have limitations and biases that could affect the program's performance. For example, the pretrained model we are building upon (cross-encoder/nli-deberta-v3-small from the Hugging Face library) may already have some biases encoded due to the data it was trained on. We trained the Model using transfer learning, meaning that we use the pretrained model's weights without alteration for every step of inference except the last one. Therefore, the initial representation and processing of the emails in the Model is determined completely by the pretrained model which could embed bias that we are not aware of. There is likely to be historical bias in the word embeddings used by the pretrained model.

Bias Types and Potential Impacts

The training data may give rise to various types of algorithmic biases that can affect the accuracy and fairness of the email sorting and prioritizing process. These biases could affect the Model's ability to accurately categorise and prioritise emails, leading to differential treatment and harm for users. We have identified four main bias types:

2. **Representation bias:** As pointed out by [Suresh and Guttag \(2021\)](#), this type of bias occurs when the training data used to develop the Model is not representative of the whole population that the model will be applied to, and it subsequently fails to generalize well for certain subsets of the use population. For example, if the training data contains a higher proportion of emails from male senders than female senders, the model may be more accurate in sorting and prioritizing emails from male senders, leading to differential treatment or exclusion of female senders.

-
3. **Confirmation bias:** This type of bias occurs when the Model relies on pre-existing assumptions and expectations that reinforce existing stereotypes or discriminatory attitudes. For example, if the Model is trained on data that contains abusive language that reflects sexist or racist attitudes, the Model may inadvertently learn to associate certain phrases or keywords with gender or racial stereotypes, leading to biased email sorting and prioritizing.
 4. **Overgeneralization bias:** This type of bias occurs when the Model generalises patterns or characteristics from the training data to new data, leading to inaccurate and unfair email sorting and prioritizing. For example, if the NLP model is trained on data that contains specific keywords related to a certain profession or industry, the model may inadvertently associate emails containing those keywords with a certain category, leading to inaccurate email sorting and prioritizing.
 5. **Deployment bias:** Deployment bias, as defined by [Suresh and Guttag \(2021\)](#), refers to the concept that machine learning models may exhibit differences in performance when deployed in different settings or environments than they were intended to be used in. Deployment bias could manifest in the Model's performance when applied to real-world email data that is different from the training data. For example, the training data may be based on emails from a specific industry or geographic region, but if the Model is deployed in a different industry or region, its performance may decrease due to differences in language or communication styles. This could result in inaccurate email sorting and prioritizing, leading to frustration and inefficiencies for users.

Mitigating Biases

It is important to identify and address these potential biases in the Model to ensure that it is fair and accurate in sorting and prioritizing emails for all users. Mitigation may involve:

- Careful selection and preprocessing of training data to ensure representativeness and inclusivity. We will include a data cleaning process in training our model for each client and set diversity and inclusion thresholds for our sample data in the design process.
- Testing the model in different environments and settings to identify potential performance differences and adapt the model accordingly. This may involve retraining or fine-tuning the Model to adjust for differences in language, communication style, or user behavior.
- Regular monitoring and evaluation of the Model's performance. We will assess whether the demographic thresholds set for each client are consistently met as the dataset grows

and monitor and evaluate the model's performance in real-world settings to ensure that any deployment biases are identified and addressed in a timely manner.

- Implementing algorithmic transparency and interpretability techniques to understand the model's decision-making process. This may involve implementing techniques such as chain-of-thought prompting to enable the model to output a textual explanation of its classification.

Future improvements to the Model will focus on incorporating strategies to mitigate biases and increase algorithmic transparency, and stakeholders will be involved in the design process to ensure diversity and inclusion.

Conclusion

This memorandum has sought to set out and analyze the key legal issues arising in relation to our group project's product 'SIFTIT'. While our preliminary findings are clear for present purposes, further research would be required in the areas of MPC status under the GDPR, and the legal ethics of AI processing of class action requests before this product could be fully commercialized.